

SCC.351: Advanced Cyber Security

Lab 1: Distributed Systems and Threat Modelling

Task 1: Threat Modelling

In this task, you will perform a STRIDE threat modelling exercise.

Before you begin, read the threat modelling cheat sheet available at https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html.

The data flow diagram on the next page was generated in OWASP Threat Dragon (<https://owasp.org/www-project-threat-dragon/>) as a demo threat model for an Online Payments Processing Platform. In the diagram, processes are shown as circles, actors as rectangles, data flows as arrows and trust boundaries as dashed boxes.

You will build a threat model based on this diagram, identifying threats and mapping them to assets and data flows.

Question 1

List the actors, processes and data flows shown in the diagram.

Question 2

For each STRIDE category, identify at least TWO threats that target an actor, process or data flow.

Use the table below to document each threat.

HINT: revisit the lecture slides for prompt questions to help identify threats.

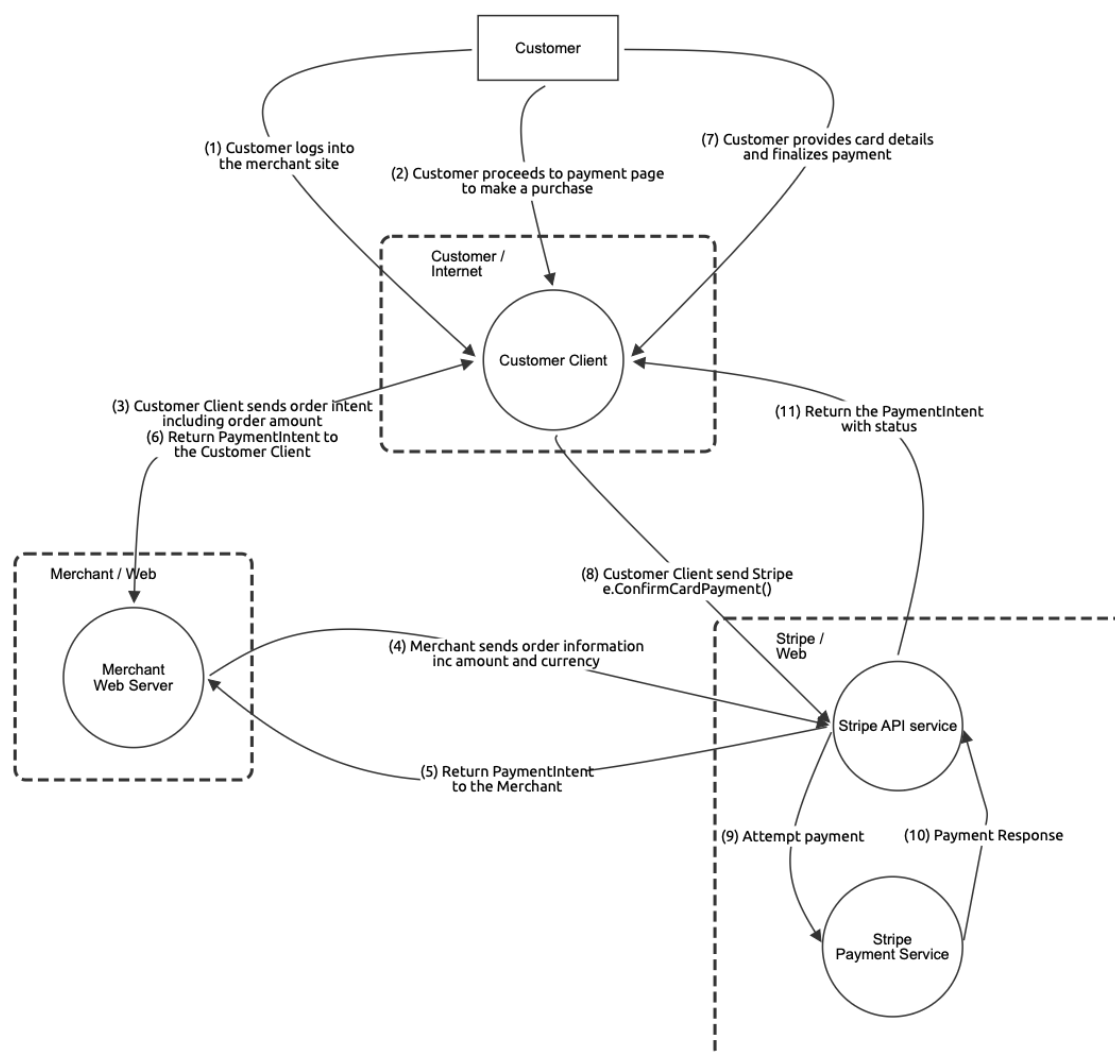
STRIDE category	Asset affected	Description of threat
Spoofing	Merchant web server	A phishing attack allows an attacker to obtain credentials for merchant staff accounts. The attacker can then compromise the accounts, manipulating orders sent from the customer.

Question 3

Select your top four threats based on likelihood and impact. Explain why these threats are most critical to address.

HINT: You may find it useful to look at the OWASP Top 10 <https://owasp.org/Top10/>, which outlines the 10 most critical risks for web applications.

Demo threat model for an online Payments Processing Platform
provided by the OWASP Threat Model Cookbook:
threat-model-cookbook/Flow Diagram/payment



Question 4 (Extra Challenge)

Identify a mitigation for each threat listed in Question 2. You can extend your table to include a Mitigation column.

STRIDE category	Asset affected	Description of threat	Mitigation
Spoofing	Merchant web server	A phishing attack allows an attacker to obtain credentials for merchant staff accounts. The attacker can then compromise the accounts, manipulating orders sent from the customer.	Multi-factor authentication for staff.

Task 2: Build a Voting Server Using a Client-Server Architecture

In this task, you will design and implement a simple client-server system that simulates a centralised voting service. The system will consist of two components:

- **Client:** submits votes and requests results.
- **Server:** receives, validates and counts votes; returns results on request.

Question 1

Create a data flow diagram that shows how information moves between the client and server.

Question 2

Build the infrastructure for the system using the skeleton files provided on Moodle (`server.py` and `client.py`). Your implementation must support the following:

- Clients send votes to the server in a structured format (e.g. JSON).
- The server validates incoming votes and updates the tally.
- Clients can request the current vote count from the server.
- The server responds with the current results.

Note that solutions to task 2 will not be provided until after the coursework submission point in week 10. Please take the opportunity during the lab sessions to ask questions about your solution.

Task 3: Incident Report

In 2011, certificate authority DigiNotar was breached and issued hundreds of fraudulent certificates.

In this task, you will write a report on the DigiNotar Certificate Authority compromise that explains what happened, models the components and trust boundaries of the system, analyses the attack, and proposes realistic mitigations and lessons for modern PKI.

You may find the following resources useful as a starting point into your research:

- <https://en.wikipedia.org/wiki/DigiNotar>
- <https://www.eff.org/deeplinks/2011/09/post-mortem-iranian-diginotar-attack>
- <https://slate.com/technology/2016/12/how-the-2011-hack-of-diginotar-changed-the-internets-infrastructure.html>

Use the following heading and guide word limits:

1. Executive summary (<100 words)

Summarise the incident, key dates and the consequences.

2. Attack timeline and technical details (300 words)

Provide a description of the incident, using the following questions to structure the section:

- What security practices did DigiNotar use before the attack.
- How did the attacker gain access to the system and what did they do upon gaining access?
- How was the attack discovered?

3. Response and remediation actions (200 words)

- How did DigitNotar respond to the attack?
- What were the operational and legal outcomes for DigiNotar?
- What changes to the industry occurred as a result of the attack?

4. Reflections (100 words)

Provide a short reflection on the practices that could have reduced the likelihood of this attack.